

Gateway 개발·사용 가이드

Gateway 가 필요한 경계와 내부 Domain 호출 경계를 혼동하지 않는 실무 가이드

Gateway/BFF/Domain 개발자를 위한 실무 가이드입니다. 외부 Entry 정책을 적용하면서 내부 Domain 호출 경계를 왜곡하지 않도록 구현합니다.

- Gateway 는 외부 Entry/Edge 정책이 필요할 때 선택합니다.
- 내부 Domain 호출은 Gateway 를 경유하지 않습니다.
- System6/operationId/상태 코드를 기준으로 장애를 추적합니다.

목차

필요한 작업을 먼저 찾고 해당 장으로 이동합니다. 페이지 번호는 최종 PDF 기준입니다.

1 Gateway 가 필요한지 먼저 판단.....	3
경로 선택.....	3
2 Route 와 Operation.....	3
식별자.....	4
3 Edge Security.....	4
상태 코드 처리.....	4
4 관측과 장애 복구.....	5
복구 확인 체크.....	5
5 Timeout·Retry·Rate Limit.....	6

Timeout·Deadline.....	6
Retry 조건.....	6
Rate Limit·Circuit.....	6
6 HA·Canary·Rollback.....	6
HA 와 Failure Domain.....	6
Canary 와 Rollback.....	7
7 개발·운영·Source.....	7
금지 우회와 Source 길찾기.....	7

1 Gateway 가 필요한지 먼저 판단

모든 내부 호출을 Gateway 에 넣지 않고 외부 Entry/Edge 정책이 필요한 경우에만 선택합니다.

경로 선택

표 1-1. 경로 선택

경로 선택의 선택 기준과 확인 항목을 빠르게 비교합니다.

상황	권장 경로	Gateway
Same JVM Domain	Caller → in-process binding → Owner Domain	사용하지 않음

상황	권장 경로	Gateway
분리 WAS/MSA 내부 Domain	Remote Adapter/Registry → Owner Domain	내부 호출 경유하지 않음
외부 Partner/Channel	External → Gateway → Target	선택/권장
관리 UI/BFF	Channel/BFF → 내부 Owner 계약	Topology 에 따라 Edge 사용

Gateway 는 외부 Entry 와 Edge 정책을 담당하는 선택 경계입니다. Domain A 에서 Domain B 로 가는 내부 호출을 Gateway 로 우회시키지 않습니다.

2 Route 와 Operation

Route 는 endpoint 를 고르고 업무 코드는 Domain/Operation 계약을 호출합니다.

식별자

표 2-1. 식별자

식별자의 선택 기준과 확인 항목을 빠르게 비교합니다.

값	Owner	검증
systemCode	시스템 정보	Target SystemCode 일치
operationId	Annotation/OpenAPI/Client/Registry/ADM/Log 공통	stable id
transactionId	거래 Context	hop 간 유지
instanceId	현재 Runtime instance	header 에 넣지 않음

3 Edge Security

인증·인가·Rate Limit·Header 검증을 Edge 에서 수행하되 업무 Owner 권한을 우회하지 않습니다.

상태 코드 처리

표 3-1. 상태 코드 처리

상태 코드 처리의 선택 기준과 확인 항목을 빠르게 비교합니다.

상태	Gateway 판단	Caller 행동
401	인증정보 없음/무효	재인증
403	권한 부족	권한/승인 확인
404	route/operation 없음	registry/version 확인
409	중복/충돌	idempotency/state 확인
429	rate limit	Retry-After/backoff
500	내부 기술오류	trace 확인
503	대상 unavailable	health/route/retry-safe 확인

4 관측과 장애 복구

Gateway trace 만 보고 전체 거래 성공을 판단하지 않고 Owner Domain 과 downstream 결과까지 연결합니다.

- System6 와 operationId 를 통해 hop 을 연결합니다.
- Side-effecting timeout 은 UNKNOWN 가능성을 유지합니다.
- Retry 는 대상 Operation 의 idempotency/side-effect 정책을 확인한 뒤 적용합니다.
- Gateway 가 unavailable 이어도 내부 Same-JVM/Remote Domain 계약 자체를 왜곡하지 않습니다.

복구 확인 체크

표 4-1. 복구 확인 체크

복구 확인 체크의 선택 기준과 확인 항목을 빠르게 비교합니다.

확인	판단	다음 조치
transactionId · operationId	요청 hop 과 Owner Operation 을 연결했는가	trace/owner 결과 대조
instanceId	실제 처리 Runtime 을 특정했는가	health/log 확인
Downstream 결과	Side Effect 결과가 확정됐는가	확정 전 blind retry 금지
UNKNOWN	recovery ledger/probe 가 필요한가	reconcile 후 최종 상태 확정
Retry safety	idempotency/side-effect 조건이 충족되는가	조건 충족 시에만 retry

5 Timeout·Retry·Rate Limit

Edge 정책은 실패를 숨기지 않고 Target Domain 의 계약과 함께 동작해야 합니다.

Timeout·Deadline

Gateway timeout 은 downstream deadline 보다 무조건 짧게 만드는 값이 아니라 전체 호출 예산과 취소/UNKNOWN 정책을 고려해 정합니다. 응답 Timeout 만으로 Side Effect 실패를 확정하지 않습니다.

Retry 조건

GET 등 Retry-safe 요청 또는 명시적 Idempotency 가 보장된 요청만 제한 재시도합니다. 내부 Domain 업무 호출의 재시도 정책을 Gateway 에서 중복 적용하지 않습니다.

Rate Limit·Circuit

429 는 정책에 따른 제한 결과이며 Client 가 무제한 Retry 하지 않도록 Retry-After/정책 정보를 제공합니다. Circuit Open 은 503 등 표준 오류 계약으로 매핑하고 trace 를 유지합니다.

6 HA·Canary·Rollback

Gateway 배포 자체의 Health 와 Route/Policy 의 기능 정상성을 분리해 확인합니다.

HA 와 Failure Domain

다중 인스턴스에서 Route/Policy/Trust 설정이 일치해야 하며 일부 Instance 의 stale 설정을 허용하지 않습니다.

Canary 와 Rollback

Canary 는 대상 Route/Operation 의 실제 거래를 검증한 뒤 확대합니다. Rollback 조건은 401/403/429/5xx 증가, Route 오류, Header/Context 손실, latency 악화를 포함합니다.

7 개발·운영·Source

Gateway 는 외부 Entry Surface 이며 내부 Domain 호출 경로가 아닙니다.

금지 우회와 Source 길찾기

Browser/untrusted Client 가 System6 보호 Header 를 임의 작성하게 두지 않고 Trusted Edge 에서 재구성합니다. 내부 Domain→Domain self-HTTP 또는 Gateway 재경유를 만들지 않습니다.

배포·복구 최종 확인

Gateway Health 만 정상이라고 배포를 완료하지 않습니다. Route·Identity·오류 의미·복구 경로를 실제 거래 기준으로 확인합니다.

확인 영역	배포 전/후 확인	실패 시 조치
Route·Operation	대상 Route 와 operationId 가 동일 Owner Domain 을 가리키는지 실제 호출	확대 중지, Route/Client mapping rollback

확인 영역	배포 전/후 확인	실패 시 조치
System6·Context	보호 Header 재구성, transactionId/original/current/caller/target 전파	Traffic 차단 후 Trust/serialization 설정 복구
오류·UNKNOWN	401/403/404/409/429/5xx 와 Timeout 의 Caller 행동이 계약과 일치	blind retry 금지, UNKNOWN 은 Probe/Reconcile
Retry·Rate Limit·Circuit	재시도 횟수·deadline·429·Circuit 상태가 중복 Side Effect 를 만들지 않음	정책 원복 또는 대상 Route 격리
Canary·Trace	Canary transactionId 가 Gateway→Owner Domain→결과까지 연결	확대 중지, offending instance 제거
Rollback	이전 Route/Policy/Trust 설정으로 되돌린 뒤 실제 거래 재검증	완료 Evidence 전 사건 종료 금지

Source: cpf-gateway · cpf-core/src/main/java/com/cpf/core/api/domain/CpfDomainClient.java · cpf-docs/deliverables/아키텍처설계서.pdf

배포 완료 판단과 Canary 확장

Gateway Health 가 정상이어도 Route/Policy 가 실제 거래 의미를 보존하는지 확인한 뒤 Traffic 을 확대합니다.

- 동일 Route 를 여러 Instance 에 배포한 뒤 routeVersion/bindingVersion/configChecksum 과 적용 ACK 가 모두 수렴했는지 확인합니다.
- Canary 거래에서 System6·operationId·Caller/Target 이 Owner Domain 까지 유지되고 401/403/429/5xx 의미가 정책과 일치하는지 확인합니다.
- Rollback 직후 동일 거래를 다시 실행해 stale Route/Trust 설정이 남지 않고 원래 latency/오류 분포로 돌아왔는지 확인합니다.

완료 Evidence

배포 완료는 Health 한 건이 아니라 Route 정본, Instance 적용, 실제 거래 추적, 승인·감사 Evidence 가 같은 변경을 가리킬 때 확정합니다.

- Route snapshot 의 routeVersion/bindingVersion/configChecksum 과 각 Instance ACK 를 함께 보존합니다.
- Canary/rollback 거래의 transactionId·operationId·Caller/Target 과 최종 Owner Domain 결과를 연결합니다.
- 변경 사유·권한·승인·실행·복구 결과를 Audit Evidence 로 남깁니다.

Source: cpf-gateway/src/main/java/com/cpf/gateway/route/CpfGatewayRouteSnapshot.java · cpf-gateway